E3 - RELATORIO DE TESTES DE SEGURANCA, VULNERABILIDADES E MITIGACAO DE SQL INJECTION

1. Escopo e Objetivo dos Testes de Seguranca

O presente documento detalha a analise de seguranca realizada no painel web (Dashboard / Flask) da Rede Comunitaria Vila Aurora. O objetivo principal consistiu em identificar falhas de injecao de codigo em campos de entrada de dados, demonstrar o vetor de ataque (SQL Injection) e comprovar a eficacia da correcao aplicada na causa raiz.

2. Demonstracao da Vulnerabilidade (Branch Vulneravel)

Na versao inicial e nao blindada da aplicacao, as consultas ao banco de dados relacional PostgreSQL eram construidas por concatenacao direta de strings fornecidas pelo usuario.

- Vetor de Ataque Utilizado: Injecao de clausulas logicas booleanas (ex: ' OR '1'='1) nos campos de autenticacao e busca do painel.
- Comportamento Observado: A consulta executada diretamente no SGBD permitiu o bypass completo do mecanismo de autenticacao, retornando registros restritos e acessos nao autorizados sem a necessidade de credenciais validas.

3. Correcao na Causa Raiz e Parametrizacao (Branch Segura)

Para sanar a vulnerabilidade em conformidade com as boas praticas de desenvolvimento seguro, a arquitetura do painel web foi modificada:

- Substituicao de Queries Dinamicas: Eliminacao total da concatenacao de strings nas instrucoes SQL.
- Consultas Parametrizadas: Implementacao de cursor com passagem de parametros isolados (bind variables / prepared statements), garantindo que os dados inseridos pelo usuario sejam tratados estritamente como literais e nunca como instrucoes executaveis pelo motor do banco de dados.
- Reteste e Validacao: Apos a aplicacao da correcao na branch segura, novas tentativas de injecao com payloads maliciosos foram bloqueadas nativamente, registrando falhas de autenticacao padrao e preservando a integridade da base de dados.